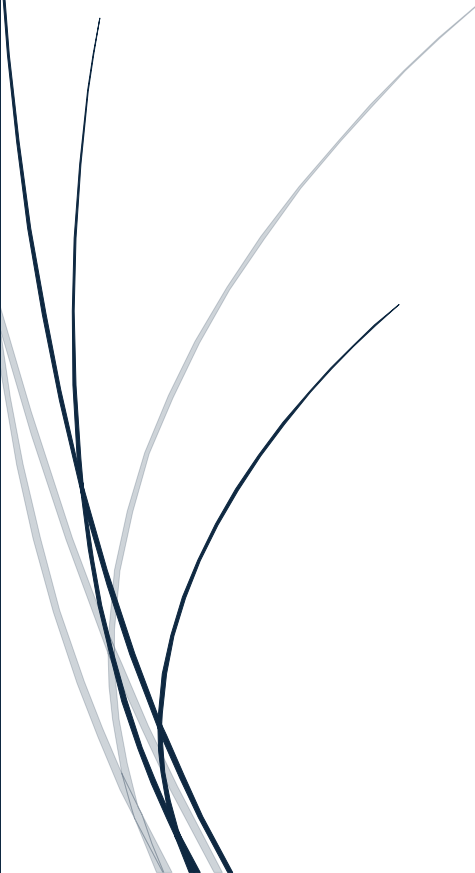




11/11/2025

Classwork Lab 3:

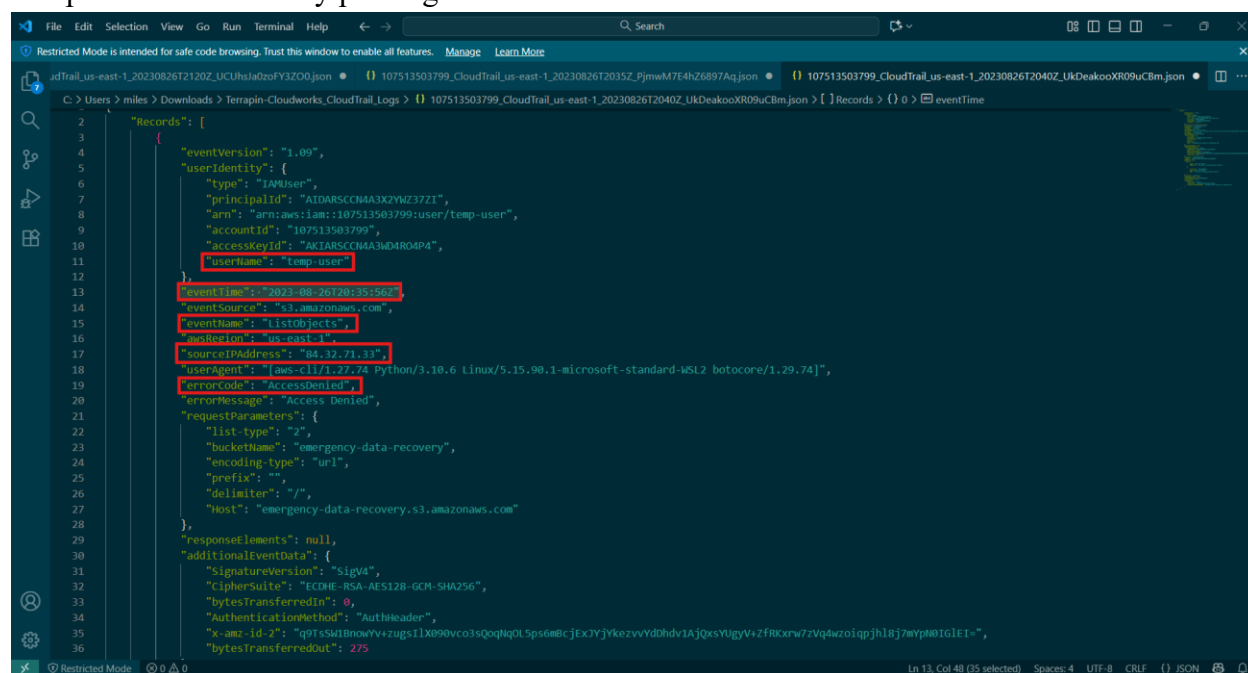
Investigating an AWS Breach with
CloudTrail & IAM



Levine, Miles L
MLEVIN56 ENPM665 0101

1. Attack Timeline

Three identities were active in the logs. The root account, the IAM user temp-user, and the assumed role AdminRole/MySession. The first suspicious action occurred at 20:35:56 UTC. The IAM user temp-user attempted to list objects in the S3 bucket emergency-data-recovery from IP 84.32.71.33. The request failed with AccessDenied. At 20:46 UTC the same user ran IAM and service enumeration commands that were denied. At 20:54 UTC temp-user used STS AssumeRole to switch into AdminRole and created a new session named MySession. At 21:17 UTC the same identity listed and downloaded files from S3. These events confirm a credential compromise followed by privilege escalation and data theft.

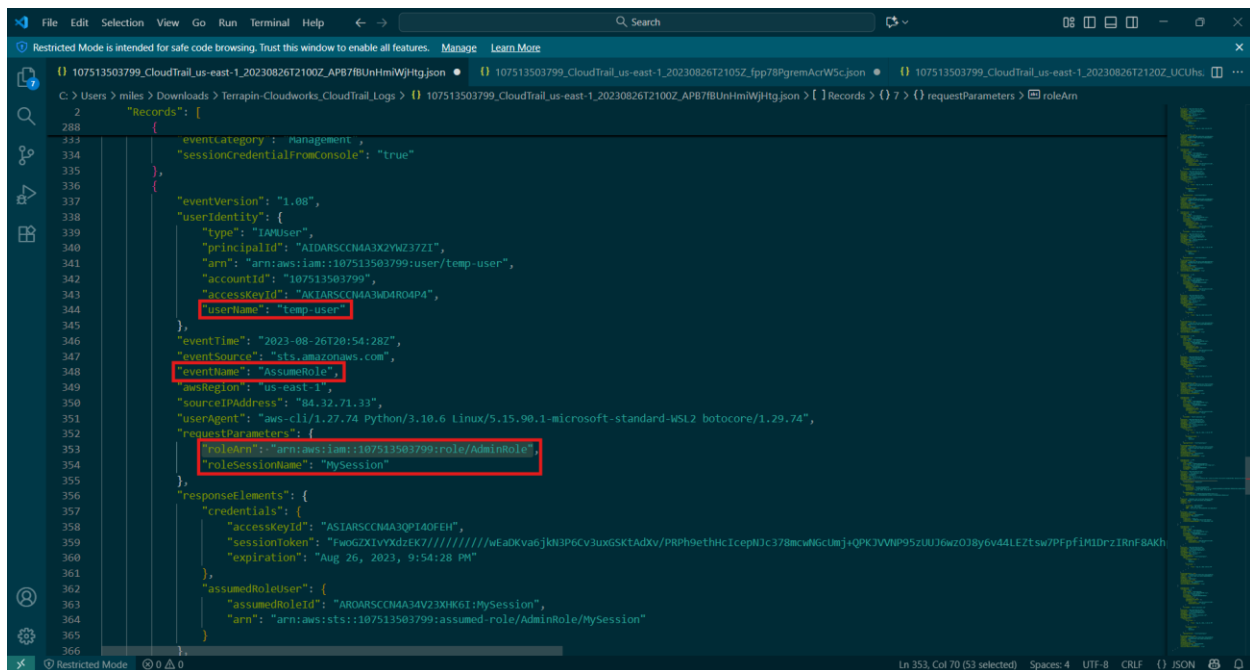


```
adTrail_us-east-1_20230826T2120Z_UCUhs1a0zofY3ZO0.json • 107513503799_CloudTrail_us-east-1_20230826T2035Z_PjmwM7E4hZ6897Aq.json • 107513503799_CloudTrail_us-east-1_20230826T2040Z_UkDeakooXR09uCbm.json
C:\Users> miles > Downloads > Terrapin-Cloudworks_CloudTrail_Logs > 107513503799_CloudTrail_us-east-1_20230826T2040Z_UkDeakooXR09uCbm.json > [ ] Records > [ ] 0 > eventTime
2
3
4
5
6
7
8
9
10
11
12
13
14
15
16
17
18
19
20
21
22
23
24
25
26
27
28
29
30
31
32
33
34
35
36
"Records": [
  {
    "eventVersion": "1.09",
    "userIdentity": {
      "type": "IAMUser",
      "principalId": "AIDARSCNAA3X2Y6Z37Z1",
      "arn": "arn:aws:iam::107513503799:user/temp-user",
      "accountId": "107513503799",
      "accessKeyId": "AKIARSCNAA3MD4R04P4",
      "userName": "temp-user"
    },
    "eventTime": "2023-08-26T20:35:56Z",
    "eventSource": "s3.amazonaws.com",
    "eventName": "listObjects",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "84.32.71.33",
    "userAgent": "aws-cli/1.27.74 python/3.10.6 linux/5.15.90.1-microsoft-standard-wsl2 botocore/1.29.74]",
    "errorCode": "AccessDenied",
    "errorMessage": "Access Denied",
    "requestParameters": {
      "list-type": "2",
      "bucketName": "emergency-data-recovery",
      "encoding-type": "url",
      "prefix": "",
      "delimiter": "/",
      "Host": "emergency-data-recovery.s3.amazonaws.com"
    },
    "responseElements": null,
    "additionalEventData": {
      "signatureVersion": "sigv4",
      "cipherSuite": "ECDHE-RSA-AES128-GCM-SHA256",
      "bytesTransferredIn": 0,
      "authenticationMethod": "AuthHeader",
      "x-amz-id-2": "qPT5wIBnowVv+zugs1IX090vco3sQoqHgDL5ps6mBcJExJYjYkezvVdDhdv1AJQxsYUgyv+ZfRkxrw7ZVq4wzoipjh18j7wYpMBIGLEI=",
      "bytesTransferredOut": 275
    }
  }
]
```

Figure 1 20:35:56 UTC: IAM user temp-user attempted to list objects in emergency-data-recovery (AccessDenied), marking the initial breach attempt.

2. Privilege Escalation or Role Abuse

The IAM user temp-user executed sts:AssumeRole at 20:54:28 UTC. The target role was arn:aws:iam::107513503799:role/AdminRole. The new session was named MySession. This changed the identity context from a basic IAM user to an administrative role. Five minutes later the actor ran GetCallerIdentity using the new session. The request returned arn:aws:sts::107513503799:assumed-role/AdminRole/MySession. The same IP range 84.32.71.x and AWS CLI user agent appeared in both events. This shows direct privilege escalation and lateral movement inside the AWS account.



```
288 {
289   "eventCategory": "management",
334   "sessioncredentialfromconsole": "true"
335 },
336 {
337   "eventVersion": "1.08",
338   "userIdentity": {
339     "type": "IAMUser",
340     "principalId": "AIDARSCMAA3X2Y6Z37Z1",
341     "arn": "arn:aws:iam:107513503799:user/temp-user",
342     "accountId": "107513503799",
343     "accessKeyId": "AKIARSCMAA3M4R04P4",
344     "userName": "temp-user"
345   },
346   "eventTime": "2023-08-26T20:54:28Z",
347   "eventSource": "sts.amazonaws.com",
348   "eventName": "AssumeRole",
349   "awsRegion": "us-east-1",
350   "sourceIPAddress": "84.32.71.33",
351   "userAgent": "aws-cli/1.27.74 Python/3.10.6 Linux/5.15.90.1-microsoft-standard-WSL2 botocore/1.29.74",
352   "requestParameters": {
353     "roleArn": "arn:aws:iam:107513503799:role/AdminRole",
354     "roleSessionName": "MySession"
355   },
356   "responseElements": {
357     "credentials": {
358       "accessKeyId": "ASIARSCMAA3QPI40FEH",
359       "sessionToken": "FwGZX1vYXdzEK7////////wEaDKva6jKH3P6Cv3uxGSKTAdXv/PRPh0ethHCIceptDc378mcwGcUj+QPK3VVRP952UJ36wz03By6v44LEZtsW7Pfpf1M1Drz1RnF8AKh",
360       "expiration": "Aug 26, 2023, 9:54:28 PM"
361     },
362     "assumedRoleUser": {
363       "assumedRoleId": "ARORARSCMAA3V23XHK61:MySession",
364       "arn": "arn:aws:sts:107513503799:assumed-role/AdminRole/MySession"
365     }
366   }
367 }
```

Figure 2 20:54:28 UTC: temp-user assumed the AdminRole via STS, elevating privileges and creating session “MySession”.

3. Resource Access & Data Handling

After gaining the AdminRole, the attacker accessed Amazon S3. At 21:17:10 UTC they listed the contents of the emergency-data-recovery bucket. Six seconds later they downloaded a file named emergency.txt. The log shows 2,232 bytes transferred out. The source IP was 84.32.71.125 and the user agent matched aws-cli/1.27.74 on WSL2. These actions confirm that the attacker used elevated privileges to exfiltrate data. The service involved was Amazon S3 and the method was a standard GetObject request.

```
2      "Records": [
72      {
74          "userIdentity": {
80              "sessionContext": {
91              }
92          },
93      },
94      "eventTime": "2023-08-26T21:17:16Z",
95      "eventSource": "s3.amazonaws.com",
96      "eventName": "GetObject",
97      "awsRegion": "us-east-1",
98      "sourceIPAddress": "84.32.71.3",
99      "userAgent": "[aws-cli/1.27.74 Python/3.10.6 linux/5.15.90.1-microsoft-standard-WSL2 botocore/1.29.74]",
100     "requestParameters": {
101         "bucketName": "emergency-data-recovery",
102         "Host": "emergency-data-recovery.s3.amazonaws.com",
103         "key": "emergency.txt"
104     },
105     "responseElements": null,
106     "additionalEventData": {
107         "signatureVersion": "sigv4",
108         "cipherSuite": "ECDHE-RSA-AES128-GCM-SHA256",
109         "bytesTransferredIn": 0,
110         "authenticationMethod": "AuthHeader",
111         "x-amz-id-2": "SS5/qv7x8d2w91kj9+88CH0XQhdklRydogiAFp5xTIPCQCz1tnXpZTr4ud1fHlPtXsG5P752beqHr57h0pK0J0MaGUBKyjyV",
112         "bytesTransferredOut": 2232
113     },
114     "requestID": "w1FD9W8B56T5MYSS",
115     "eventID": "2c7763bf-100b-42dc-ba37-2937e5530ada",
116     "readOnly": true,
117     "resources": [
118         {
119             "type": "AWS::S3::Object",
120             "ARN": "arn:aws:s3:::emergency-data-recovery/emergency.txt"
121         }
122     ]
123 }
```

Figure 3 21:17:16 UTC: AdminRole/MySession downloaded emergency.txt from emergency-data-recovery, confirming data exfiltration.

4. Indicators of Compromise (IoCs)

1. IP addresses in the 84.32.71.0/24 range were active across all phases of the attack.
2. User agents identified as aws-cli/1.27.74 Python/3.10.6 on Linux WSL2, which differs from typical Terrapin CloudWorks infrastructure.
3. Repeated AccessDenied responses on IAM and S3 APIs from the same identity indicate credential testing.
4. A single IAM user performing STS AssumeRole into an administrative role is an anomaly.
5. The root account operated without MFA enabled, exposing a critical attack vector.

```
1 {
2   "Records": [
3     {
4       "eventVersion": "1.09",
5       "userIdentity": {
6         "type": "IAMUser",
7         "principalId": "AIDARSCN4A3X2YVZ37Z1",
8         "arn": "arn:aws:iam:107513503799:user/temp-user",
9         "accountId": "107513503799",
10        "accessKeyId": "AKIARSCN4A3MDH04PA",
11        "userName": "temp-user"
12      },
13      "eventTime": "2023-08-26T20:35:56Z",
14      "eventSource": "s3.amazonaws.com",
15      "eventName": "listObjects",
16      "awsRegion": "us-east-1",
17      "sourceIPAddress": "84.32.71.33",
18      "userAgent": "aws-cli/1.27.74 Python/3.10.6 Linux/5.15.90.1-microsoft-standard-WSL2 boto3/1.29.74",
19      "errorCode": "AccessDenied",
20      "errorMessage": "Access Denied",
21      "requestParameters": {
22        "list-type": "2",
23        "bucketName": "emergency-data-recovery",
24        "encoding-type": "url",
25        "prefix": "",
26        "delimiter": "/",
27        "host": "emergency-data-recovery.s3.amazonaws.com"
28      },
29      "responseElements": null,
30      "additionalEventData": {
31        "signatureVersion": "Sigv4",
32        "cipherSuite": "ECDHE-RSA-AES128-GCM-SHA256",
33        "bytesTransferredIn": 0,
34        "authenticationMethod": "AuthHeader",
35        "x-amz-id-2": "qPT5SM1BnowVv+zugs1IX090vco3sQoqgDx5ps6mBcJEx3YjYkezyvVdDhdv1AJqxsYUgyVzZfRcRw7zVq4wzoipjhl8j7wYpM0tG1E1-",
36        "host-Header-Forwarded": "775"
37      }
38    }
39  ]
40 }
```

Figure 4 Example IoCs: IP 84.32.71.33 and AWS CLI/WSL2 user agent observed across multiple denied requests.

5. Prevention Recommendations & Reflection

- Enforce MFA for all identities including the root account.
- Apply least-privilege IAM policies and remove unused users or roles.
- Enable AWS GuardDuty and CloudTrail real-time alerts for suspicious STS or S3 events.
- Restrict role assumption through Service Control Policies and IAM conditions.
- Configure S3 buckets with object-level logging and deny public or cross-account access.

This investigation showed how small credential leaks can lead to full compromise. Reviewing CloudTrail data revealed how an attacker moves from initial access to data theft. The process demonstrated how detailed log analysis supports faster detection and stronger cloud defense planning.

```
1 {
2   "Records": [
3     {
4       "eventVersion": "1.09",
5       "userIdentity": {
6         "type": "root",
7         "principalId": "107513503799",
8         "arn": "arn:aws:iam::107513503799:root",
9         "accountId": "107513503799",
10        "accessKeyId": "ASIARSCCMA3JVLHVVV",
11        "sessionContext": {
12          "attributes": {
13            "creationDate": "2023-09-26T18:45:20Z",
14            "mfaAuthenticated": "false"
15          }
16        },
17        "eventTime": "2023-09-26T20:28:18Z",
18        "eventSource": "s3.amazonaws.com",
19        "eventName": "ListBuckets",
20        "awsRegion": "us-east-1",
21        "sourceIPAddress": "84.32.71.11",
22        "userAgent": "[S3Console/0.4, aws-intel/3 aws-sdk-java/1.12.488 linux/5.10.186-157.751.amzn2int.x86_64 OpenJDK_64-Bit_Server_VM/25.372-b08 java/1.8.0_372",
23        "requestParameters": {
24          "Host": "s3.amazonaws.com"
25        },
26      },
27      "responseElements": null,
28      "additionalEventData": {
29        "signatureVersion": "Sigv4",
30        "cipherSuite": "ECDHE-RSA-AES128-GCM-SHA256",
31        "bytesTransferredIn": 0,
32        "authenticationMethod": "AuthHeader",
33        "x-amz-id-2": "aqzj0zrdgucq8AOuIji63lMSAS8jQ40rR3bxiq1ua580udIhwylTP6qfSB1ErABcmthbKv4tG8k-",
34        "bytesTransferredOut": 703
35      }
36    }
37  ]
38}
```

Figure 5 Root account activity without MFA enabled, highlighting the need for multi-factor authentication enforcement.